

JTAGent — P0/P1 Post-Implementation Verification

Verification date: 2026-09-30 (America/New_York)

Reviewer role: independent embedded-systems and software QA verification

Scope: software tests and non-mutating live-status checks only

1. Evidence-based overall verdict

Verdict: SOURCE VERIFIED WITH MINOR GAPS; CURRENT LIVE DEPLOYMENT BLOCKED.

The checked-out implementation satisfies the core P0/P1 safety and evidence requirements in isolated mock/scripted execution. The full Python suite passed (115 tests), the canonical Playwright suite passed twice (12 tests each, including once under hostile inherited live/cloud settings), frontend production build and generated-contract checks passed, and a browser-driven mock workflow produced a bundle that the offline CLI verified both before and after the test services stopped.

The processes currently bound to 127.0.0.1:8000 and :8001 are older than the checked-out P0/P1 source. Both /healthz responses contain only {"status": "ok"}, and the live orchestrator has no /api/readiness route (404). Therefore the connected hardware stack has **not** loaded status schema v2 or the build identifiers verified in isolation. No physical operation was issued during this review.

The application is **not ready to begin the proposed bounded live read in its current loaded state**. It becomes a candidate only after an intentional edge/orchestrator restart, authenticated confirmation of schema v2/build IDs and all readiness layers, and separate authorization for the documented 16-byte physical validation.

2. Repository and runtime inventory

Item	Observed value	Disposition
Repository	JTAGent-An-Autonomous-AI-Copilot-for-Embedded-Security	Accessible
Branch	codex/uboot-security-audit	Recorded
HEAD	1208a1b88fccae95d2cebee082227b3c1d9427a4	Recorded
Commit subject	Verify live JTAG and Nebius audit paths	Recorded
Working tree	Material tracked modifications plus new P0/P1 source, tests, docs and generated assets	Dirty; commit alone is insufficient provenance
Live dashboard	127.0.0.1:8000, PID 29820	Preserved
Live edge	127.0.0.1:8001, PID 3800	Preserved
OpenOCD	loopback ports 3333/3334/4444/6666, PID 11076	Preserved; never restarted or commanded
Live schema/build	Legacy health only; /api/readiness = 404	Blocked / stale runtime
Live backends	Authenticated observation: openocd target, scripted inference, target reported running, recovery false	Historical observation from this review; old API contract
Isolated build	1208a1b+dirty:ad784a28de5c for edge and orchestrator	Verified at process startup

Item	Observed value	Disposition
Isolated backends	mock target, scripted inference, UART/live-JTAG disabled	Verified

Relevant uncommitted implementation areas include `contracts/build.py`, `contracts/status.py`, `edge/app.py`, `edge/service.py`, `orchestrator/app.py`, `orchestrator/bundle.py`, `analysis/bundle_verify.py`, `scripts/test_stack.py`, `scripts/verify_bundle.py`, `status/bundle` tests, and generated frontend `contracts/components`. Existing user changes were not reset, cleaned, or committed.

3. Requirements-to-test matrix

Acceptance criterion	Implementation evidence	Test method	Expected	Actual evidence	Result
Versioned layered target status	<code>contracts/status.py</code> , <code>contracts/models.py</code> , <code>edge/service.py</code> , <code>ReadinessPanel.tsx</code>	20 focused status tests; isolated API; browser	Schema v2, unknown remains unknown, distinct layers	All status tests passed; browser showed application/debugger/target/snapshot/recovery/schema separately	Pass (source)
Loaded build identity and drift	<code>contracts/build.py</code> ; <code>health/readiness</code> endpoints	Start isolated services, record IDs, add source file, query again	Loaded ID stays fixed; drift changes	IDs stayed ...ad784a28de5c; both drift flags changed false→true	Pass
Fail-closed live execution	<code>contracts/status.py</code> , <code>orchestrator/app.py</code> , Attack Lab gates	Fixture matrix + direct API execution tests + legacy frontend tests	No hardware request when readiness incomplete	409 responses with specific reason; edge post count unchanged	Pass
Complete durable evidence bundles	<code>orchestrator/bundle.py</code> , <code>analysis/bundle_verify.py</code>	Mock browser export, focused tests, CLI before/after process stop	Consistent artifacts; durable offline verification	VERIFIED: 22 checks passed; same result after services stopped	Pass
Honest metadata-only/historical evidence	<code>bundle/report</code> code	Fixture variants	No false complete claim; unknown remains unknown	INCOMPLETE for withheld raw; historical acquisition remains unknown	Pass
Workbench runtime contracts and recovery	<code>generated/api.d.ts</code> , <code>validators</code> , <code>contract.ts</code> , <code>ErrorBoundary.tsx</code>	contract drift/type checks; 12 Playwright cases; manual null-capture plan	Valid zero/null renders; malformed data fails inline; app survives	Suite passed; no-capture plan rendered; no browser error logs	Pass
Isolated Playwright execution	<code>scripts/test_stack.py</code> , global <code>setup/fixtures/config</code>	Canonical suite with ports 8000/8001 occupied; hostile parent env; controlled failure; repeat	Only mock/scripted child services; clean process teardown	12/12 twice; original live PIDs unchanged; failure teardown succeeded	Pass, with cleanup gap
Prepared bounded live validation	<code>docs/live-validation-procedure.md</code> , <code>tests/test_live_rehearsal.py</code>	Source inspection and offline rehearsal only	Exact minimal procedure and rollback criteria	Procedure exists and fixture rehearsal passes; no physical run authorized	Prepared, not executed
Current live application loaded intended build	running processes	Non-mutating health/readiness/browser checks	Schema v2 and build IDs loaded	Legacy health; readiness 404	Fail (deployment)

4. Commands and actual results

Command	Result
<code>uv run pytest -q</code>	115 passed , one Starlette/AnyIO deprecation warning, ~29.6 s
<code>uv run pytest tests/test_status.py tests/test_bundle.py -vv</code>	29 passed , one deprecation warning, 5.01 s

Command	Result
temporary direct export-auth probe	1 passed ; unauthenticated run, plan and export routes all returned 401; probe removed
uv run ruff check analysis config contracts edge orchestrator scripts tests	Passed
uv run ruff format --check analysis config contracts edge orchestrator scripts tests	46 files already formatted
uv run python scripts/generate_contracts.py --check	Passed; no contract drift
npm run types:check	Passed; generated api.d.ts matches OpenAPI
npm run build	Passed; Vite production build completed
npm test	12 passed with live ports occupied
hostile inherited environment + npm test	12 passed ; still mock/scripted, no live JTAG/UART/cloud mode
controlled failing Playwright case	Failed as intended; global teardown completed; temporary spec removed
uv run python scripts/verify_bundle.py <isolated-bundle>	VERIFIED: 22 checks passed, 0 failed, 0 unverifiable before and after service shutdown

Meaningful warning: Starlette's `anyio.abc.BlockingPortal` alias is deprecated. It is not a functional failure but should be removed through dependency compatibility maintenance.

5. Browser and API observations

Manual browser verification used the current frontend against a fresh isolated mock/scripted stack:

- Login succeeded without exposing the generated credential in the report.
- Readiness showed schema v2, build IDs, mock target, scripted inference, running target state, snapshots armed, recovery false and a clear `not_live_backend` blocker.
- A two-capture investigation completed, displaying addresses, 256/256 lengths, SHA-256 values, ARM decoder/version, registers, findings, uncertainty and acquisition/restoration messages.
- Local raw-inclusive export displayed VERIFIED and the offline command.
- Attack Lab clearly displayed REAL JTAG DISABLED and kept the physical snapshot step in pending approval; no physical action was executed.
- Workbench rendered a selected retained plan containing zero captures without blanking, enabled neither advice nor patch execution, and displayed NO CAPTURE / LIVE WRITES DISABLED.
- Browser warning/error log for this flow was empty.
- At 390×844, content reflowed into cards, but the bottom navigation overlapped the Workbench content. This is recorded as P2.

The new frontend against the old live orchestrator fails closed. Automated browser coverage verified both legacy flat edge status and an old orchestrator missing readiness. The current live page did not emit console errors at the login boundary.

6. Status and execution negative tests

Condition	Actual behavior	Result
Current supported status	Compatible; mock audits allowed, physical operations not applicable	Pass

Condition	Actual behavior	Result
Old flat schema	legacy_flat_schema; UI degraded; audit API 409; no snapshot/session post	Pass
Missing required fields / wrong types / non-object	malformed_status; neither run nor live ready	Pass
Unsupported version (including boolean version)	unsupported_schema_version	Pass
Edge unavailable	Config remains usable for offline context; target fields unknown; audit API 409	Pass
OpenOCD unreachable	Debugger false, target communication unknown, debugger_unreachable	Pass
Debugger version false/unknown	debugger_version_incompatible	Pass
Target communication failed/unknown	Specific blocker; never positive readiness	Pass
Execution state null/unknown	execution_state_unknown	Pass
Snapshots unarmed	snapshots_not_armed	Pass
Recovery required	recovery_required; audit API 409	Pass
Status stale	status_stale; run/live not ready	Pass
Direct live-step request while debugger down	409, approved step remains retryable, no edge post	Pass
Source changes after process start	Loaded ID unchanged; drift flags true	Pass

The running state is not conflated with debugger availability: an unavailable debugger yields target communication unknown, not "running/ready." Offline configuration/evidence remains viewable when the edge is unavailable or incompatible.

7. Evidence-bundle and verifier results

The export contains a manifest, JSON report, Markdown report and binary captures. Focused tests verified run/plan relationships; virtual/physical address metadata; returned/requested lengths; SHA-256 over raw bytes; timestamps; method; target state before/capture/after; restoration/recovery; register links; non-atomic register warning; decoder architecture/endianness/version; edge/orchestrator provenance; findings; uncertainty; and inference mode.

Variant	Expected / observed disposition
Valid complete fixture	VERIFIED; CLI exit 0
One flipped byte	FAILED; artifact/hash check identifies modification; CLI exit 1
Wrong length	FAILED
Address moved outside approved range	FAILED with range check
Missing raw artifact	FAILED
Unsafe . . / artifact path	FAILED with unsafe-path detail
Unsupported format/version	UNSUPPORTED; exit 3
Altered decoded instruction	FAILED with instruction check
Metadata-only / raw withheld	INCOMPLETE; no independent byte claim; exit 2
Historical capture without acquisition metadata	INCOMPLETE; acquisition remains unknown
Altered Markdown / report hash	FAILED

The valid browser-exported bundle independently decoded 00 00 a0 e3 as ARM mov r0, #0, 01 10 80 e2 as add r1, r0, #1, and 1e ff 2f e1 as bx lr. Its CLI verifier reported 22 passing checks. The bundle also warns that memory and registers are separate debugger reads and are not atomic.

Raw export follows the explicit operator checkbox and stays local. Tests confirm raw bytes are absent from run state, Markdown/JSON reports and model input. Export routes require authentication. Bundles remain verifiable after service shutdown/restart. Hash verification proves consistency with supplied bytes, **not** authentic hardware acquisition.

8. Playwright isolation and cleanup

The test launcher allocates four ephemeral loopback ports, excludes 3333/3334/4444/6666/8000/8001, creates unique authentication and export directories, forces TARGET_BACKEND=mock, INFERENCE_BACKEND=scripted, disables live JTAG/UART and strips inherited OpenOCD, target-profile, UART, replay and Nebius settings.

Normal, repeated and deliberately failing Playwright runs completed without touching live services. After teardown, only original PIDs 11076, 29820 and 3800 remained on the relevant ports. A source-drift probe and temporary authentication regression test were removed.

Gap: startup failure/port-allocation race was not deliberately reproduced end-to-end. Unit coverage confirms forbidden live ports are never selected, but the launcher releases an ephemeral socket before the child binds and has no explicit retry path. Test-stack temporary directories also remained under %TEMP% after teardown, including synthetic exports/logs.

9. Current live-status observations

- Dashboard and edge liveness answer on loopback.
- Both health bodies are legacy {"status": "ok"} without build provenance.
- /api/readiness returns 404.
- OpenOCD remains bound only to loopback and was not queried through telnet/TCL/GDB.
- Authenticated legacy configuration observed earlier in this review reported OpenOCD target backend, scripted inference, target running, recovery false, UART COM12 and physical region 0x402F0400–0x402F0440.
- The old process retained no investigation runs and two Attack Lab plans; the new persistent export listing is unavailable from that process.
- No new snapshot, halt/resume, reset, write, breakpoint, UART interruption or cloud call occurred.

This is an operational version skew, not proof that the new source is broken. It must be corrected before live validation.

10. Remaining defects and gaps

P1 — Running edge/orchestrator have not loaded P0/P1 code

Example: a researcher sees a working dashboard on port 8000, but the server cannot provide schema v2/readiness/build identity.

Impact: the current process cannot prove the new fail-closed contract before a physical action.

Fix criteria: intentional restart using the reviewed source; /healthz includes per-process build identity; authenticated /api/readiness reports schema v2, compatible status, matching expected backend, debugger/version/target/snapshot/recovery layers and no unexplained blocker.

P2 — Narrow Workbench navigation overlays content

Example: at 390×844 the fixed bottom navigation overlaps the “Debugger guidance” card.

Impact: reduced usability on narrow displays; controls can be obscured.

Fix criteria: add bottom safe-area/content padding or non-overlapping mobile navigation; add a 390×844 Playwright screenshot/assertion proving all primary controls remain reachable.

P2 — Isolated test artifacts are not removed

Example: multiple `jtagent-test-stack-*` directories remained in `%TEMP%` after normal and controlled-failure runs.

Impact: accumulated logs/synthetic raw exports and disk usage; future real-like fixtures could raise retention concerns.

Fix criteria: teardown removes its own temporary root unless a documented keep-artifacts flag is set; regression test verifies removal after success and failure.

P2 — Occupied-port/startup-failure path lacks explicit end-to-end proof

Example: the launcher checks an ephemeral port and releases it before `uvicorn` binds; a race could make startup fail.

Impact: flaky browser tests, though live ports remain excluded and cleanup is defensive.

Fix criteria: reserve ports until child startup or retry allocation; add a deterministic startup-failure/occupied-port test that confirms child-only cleanup and a useful diagnostic.

P2 — Frontend asset identity is indirect

Process build fingerprints cover Python packages, not the exact `web/dist` bytes. Runtime schema validation safely blocks legacy responses, but an operator cannot identify the loaded frontend bundle from the displayed build ID.

Fix criteria: embed a frontend build ID/content hash in the production bundle and display/report it with edge/orchestrator IDs.

Maintenance — dependency deprecation warning

Update the compatible `Starlette/AnyIO` dependency set so the full suite has no `BlockingPortal` deprecation warning.

11. Reproduction steps

Source verification

```
uv run pytest -q
uv run pytest tests/test_status.py tests/test_bundle.py -vv
uv run ruff check analysis config contracts edge orchestrator scripts tests
uv run ruff format --check analysis config contracts edge orchestrator scripts tests
uv run python scripts/generate_contracts.py --check
cd web
npm run types:check
npm run build
npm test
```

Non-mutating live version-skew check

```
Invoke-WebRequest -UseBasicParsing http://127.0.0.1:8000/healthz
Invoke-WebRequest -UseBasicParsing http://127.0.0.1:8001/healthz
Invoke-WebRequest -UseBasicParsing http://127.0.0.1:8000/api/readiness
```

Expected for the presently loaded legacy processes: `simple status: ok` health bodies and a 404 readiness response. Do not mistake liveness for live-operation readiness.

Offline bundle verification

```
uv run python scripts/verify_bundle.py <bundle-directory>
```

Expected complete fixture result: VERIFIED, 22 checks passed. Metadata-only expected result: INCOMPLETE, never verified.

12. Checks requiring separate hardware authorization

No item below was performed. The prepared procedure requires a new explicit authorization after the updated services are loaded and readiness is reviewed:

1. Confirm authenticated schema v2/readiness and exact loaded build IDs.
2. Confirm OpenOCD version compatibility, debugger reachability, target communication, running state, snapshots armed and recovery false.
3. Approve exactly one bounded 16-byte snapshot at the documented approved SRAM address.
4. Verify target restoration to running and recovery false.
5. Compare the exported 16 bytes with an independently obtained, separately authorized read.
6. Run the offline verifier and record bundle provenance.

Excluded without further authorization: additional physical snapshots, halt/resume, reset, writes, breakpoints, UART interruption and any cloud transmission of hardware evidence.

Final answers

- **Verified changes:** status v2 contract, layered readiness, fail-closed server gates, loaded-code identity and drift semantics, evidence bundle/export/verifier behavior, authentication, Workbench contract/error handling, mock workflow and Playwright isolation.
- **Failed acceptance criteria:** the currently running live edge/orchestrator did not load the intended schema/build; narrow mobile layout overlaps content.
- **Untested or partial:** real hardware validation, cloud inference with hardware evidence, UART intervention, deterministic occupied-port startup failure, and exact frontend-asset provenance.
- **Ready for the proposed bounded live validation? No—not in the current loaded runtime.** After an intentional service restart and successful non-mutating readiness review, the source is sufficiently verified to request separate authorization for the documented single 16-byte validation.